



Audittens

ZKsync OS Security Review

November 4, 2025

Contents

1	About Audittens	3
2	About ZKsync OS	3
3	Risk classification	3
4	Executive summary	4
4.1	Engagement overview	4
4.2	Scope	4
4.3	Summary of findings	4
5	Assumptions and limitations	5
5.1	Explicit invariants of the codebase usage	5
5.2	Limitations	5

1 About Audittens

Audittens is an audit company with expertise across various sectors of Web3 security.

What truly sets us apart is that our team consists entirely of top participants in mathematics and competitive programming competitions, uniquely equipping us to rapidly analyze codebases, uncover explicit and implicit invariants, and identify unique attack vectors.

You can subscribe and learn more about us at <https://x.com/Audittens>.

2 About ZKsync OS

ZKsync OS is a system-level implementation for ZKsync's state transition function.

Under ZKsync's new architecture, execution is decoupled from proving. ZKsync OS acts as the operation layer in this new architecture. It takes block data and an initial state as input and computes the new state after the application of the block. ZKsync OS is implemented as a Rust program.

You can subscribe and learn more about the project at <https://zksync.io>.

3 Risk classification

The severities of the issues are determined based on the following properties:

- Critical — results in a significant loss of assets within the protocol, a major deviation from the expected behavior of protocol components, and/or a violation of key security invariants.
- High — causes loss of assets within the protocol and/or general violations of protocol security invariants, with limitations on the variety of potential attacks.
- Medium — enables barely profitable attacks on the protocol, violations of security invariants that pose minimal risk to protocol users, and/or functionality limitations affecting only a relatively small subset of users.
- Low — enables griefing attacks on the protocol, unexpected changes in the protocol's behavior that are imperceptible, and/or functionality limitations with negligible impact on the security of the protocol.
- Informational — issues that have no practical impact on the security of the current version of the protocol but could potentially lead to more serious consequences in future updates, create the possibility for incorrect use of the protocol by users, and/or result in a significant decline in code quality, making maintenance more challenging.

While determining the severity of issues, the constraints required for successful attacks and the potential actions to address their consequences are taken into account in the decision-making process.



4 Executive summary

4.1 Engagement overview

ZKsync Security Council Foundation engaged Audittens to review the security of components of ZKsync OS's implementation. Between June 23, 2025 and November 4, 2025, a team of 3 security researchers reviewed the provided source code over a total of 11 weeks within this period. After the completion of the fix period by ZKsync's team, the full security review was finalized by reviewing the corresponding commits.

4.2 Scope

Security review for the components of the `matter-labs/zksync-os` repository was provided.

The following parts of the codebase were within the scope of the security review:

Commit	Scope
50dd547	parts of <code>basic_bootloader</code> , <code>basic_system</code> , <code>storage_models</code> and <code>zk_ee</code> crates
aad3fab	pull request “ <code>multiblock batch proving</code> ”
c3698e4	parts of <code>basic_bootloader</code> , <code>basic_system</code> , <code>evm_interpreter</code> , <code>forward_system</code> , <code>proof_running_system</code> and <code>system_hooks</code> crates

4.3 Summary of findings

Severity \ Status	Status		
	Acknowledged	Fixed	Total
Critical	0	5	5
High	1	7	8
Medium	3	8	11
Low	5	10	15
Informational	20	13	33
Total	29	43	72

Table 1. Distribution of found issues.



5 Assumptions and limitations

5.1 Explicit invariants of the codebase usage

The security review was conducted assuming that:

1. ZKsync account abstraction, paymaster and EIP-712 transactions will be deprecated.
2. ZKsync OS will not be used as a settlement layer.

5.2 Limitations

The security review was provided as is. Any subsequent changes may introduce new vulnerabilities and require a separate security review. Fixes for all findings have been reviewed within the limited scope (in the context of only relevant protocol components).

